



Orviohub Superadmin Dashboard Plan

The superadmin dashboard should provide a complete operational view of every organization, application, branch, team, billing state, onboarding state, and audit history. It should allow support and platform administrators to investigate problems and perform carefully controlled administrative actions without exposing passwords, tokens, payment secrets, private session data, or unnecessary personal information.

The dashboard should be designed as a **read-heavy, low-cost modular monolith**. Avoid real-time streaming, expensive analytics infrastructure, or duplicated reporting databases in the MVP. Use paginated Convex queries, indexed counters, server-side aggregation, and cached summary values where appropriate. The workspace architecture already defines workspace-scoped audit logs, product memberships, branches, applications, and indexed queries that can support this dashboard. ^[1]

1. Dashboard Objectives

The superadmin should be able to answer:

- How many organizations exist?
- Which organizations are active, trialing, suspended, archived, or past due?
- Who owns each organization?
- Which applications are active in each organization?
- Which applications failed activation or onboarding?
- How many branches does each application or organization have?
- How many team members belong to each branch?
- Which users have access to which applications and branches?
- Which organizations have billing problems?
- Which organizations have incomplete onboarding?
- What actions have occurred in an organization?
- Which administrative changes were made by platform staff?
- Which organizations require support attention?
- Which records are approaching limits or violating consistency rules?

The dashboard should not be a second business application. It should be a **platform control and support console**.

2. Main Navigation

Use the following MVP navigation:

- Overview
- Organizations
- Users
- Applications
- Branches
- Billing
- Onboarding
- Audit Logs
- Support Notes
- System Settings

Overview

Platform-level summary and alerts.

Organizations

Searchable list of every organization with drill-down access.

Users

Searchable users list and user detail pages.

Applications

Application registry, activation status, and organization-level application usage.

Branches

Cross-organization branch search and branch-level details.

Billing

Subscriptions, payment status, entitlements, failed payments, and mismatches.

Onboarding

Incomplete user, organization, and application onboarding.

Audit Logs

Global and filtered audit history.

Support Notes

Internal notes attached to organizations, users, applications, or branches.

System Settings

Plans, application registry, administrative roles, and security configuration. Keep this restricted to a higher-level platform administrator if multiple superadmin levels are introduced later.

3. Overview Dashboard

The overview should use inexpensive aggregate counters rather than calculating every organization from scratch on every page load.

Summary cards

Display:

Metric	Example
Total organizations	1,248
Active organizations	1,010
Trial organizations	148
Past-due organizations	42
Suspended organizations	18
Archived organizations	30
Total users	4,920
Active applications	1,540
Total branches	2,870
Failed onboarding flows	74

These counters should be updated when relevant events occur, such as organization creation, application activation, branch creation, suspension, restoration, and archival.

Operational alerts

Show only actionable alerts:

- Payment verified but subscription remains inactive.
- Active subscription with missing entitlements.
- Active application with incomplete provisioning.
- Application marked active but no primary branch exists.
- Organization with no active owner.

- Duplicate active subscription.
- Failed payment beyond grace period.
- Excess resources after downgrade.
- Suspicious cross-tenant access attempts.
- Repeated webhook processing failures.
- Large number of failed synchronization records.
- Organization deletion process stuck.
- Invitation or onboarding process stuck.

Recent platform activity

Show a paginated feed of:

- New organizations.
- New users.
- Payment successes and failures.
- Application activations.
- Organizations suspended or restored.
- Branches created.
- Large membership changes.
- Administrative changes.
- Security events requiring attention.

Do not load the entire audit table for this feed. Store or query a small recent-activity view indexed by timestamp.

4. Organization List

Route:

```
/admin/organizations
```

Search

Allow search by:

- Organization name.
- Organization ID.
- Slug.
- Owner name.
- Owner email.

- Billing email.
- Application name.
- Branch name.
- Member email.
- Paystack reference.

Filters

- Active.
- Creating.
- Setup incomplete.
- Trial.
- Past due.
- Suspended.
- Archived.
- Deleting.
- Deleted.
- Free plan.
- Standard plan.
- Premium plan.
- Has Inventory.
- Has incomplete onboarding.
- Has failed payment.
- Has no active owner.
- At member limit.
- At branch limit.
- At product limit.
- Created date.
- Last activity date.

Organization table

Display:

Column	Purpose
Organization	Name, logo, and ID
Owner	Name and email
Status	Active, trial, suspended, etc.

Column	Purpose
Plan	Free, Standard, Premium
Applications	Active application count
Branches	Total active branch count
Members	Active member count
Billing	Payment and subscription status
Onboarding	Completion status
Last activity	Most recent meaningful event
Created	Organization creation date
Actions	Open, suspend, archive, restore

Use server-side pagination. Do not fetch every organization to the browser.

5. Organization Detail Page

Route:

```
/admin/organizations/:workspaceId
```

The organization detail page is the main superadmin workspace.

Header

Display:

- Organization name.
- Organization ID.
- Logo.
- Owner.
- Organization type.
- Country and city.
- Currency and timezone.
- Current status.
- Current plan.
- Subscription status.
- Created date.
- Last activity.
- Risk or support indicators.

Header actions:

- Suspend organization.
- Restore organization.
- Archive organization.
- Request deletion review.
- Recalculate entitlements.
- Add support note.
- Export organization summary.
- Open audit log.

Tabs

Overview
Applications
Branches
Members
Onboarding
Billing
Usage
Audit Log
Support Notes
Data and Security

6. Organization Overview

Display a summarized view of the organization.

Business information

Read-only by default:

- Name.
- Slug.
- Business type.
- Category.
- Country.
- State.
- City.
- Address.
- Phone.
- Email.

- Currency.
- Timezone.
- Logo.
- Creation date.
- Last update date.

Ownership

Display:

- Current owner.
- Owner user ID.
- Owner email.
- Owner account status.
- Date ownership was assigned.
- Ownership-transfer history.
- Whether the organization currently has more than one owner.

Health summary

Display:

- Workspace status.
- Billing status.
- Onboarding status.
- Number of active applications.
- Number of suspended applications.
- Number of active branches.
- Number of suspended branches.
- Number of active members.
- Number of pending invitations.
- Last successful activity.
- Last failed operation.
- Current system warnings.

Superadmin actions

Allowed:

- Read organization details.
- Add an internal support note.

- Suspend organization.
- Restore organization.
- Archive organization.
- Recalculate entitlements.
- Export a permitted organization summary.

Restricted:

- Change ownership.
- Change billing plan.
- Extend a trial.
- Modify entitlements.
- Delete the organization.
- Change business data.

These actions should be separately permissioned and require stronger confirmation.

7. Applications View

Route:

```
/admin/organizations/:workspaceId/applications
```

This page should show every application associated with the organization.

Application table

Display:

Field	Description
Application	Inventory, Tasks, CRM, etc.
Status	Inactive, activating, setup incomplete, active, suspended
Plan entitlement	Included, trial, unavailable
Activated by	Admin or member who activated it
Activated at	Timestamp
Onboarding	Not started, in progress, completed, failed
Branches	Number of application branches
Members	Number of application members
Usage	Products, transactions, or relevant limits
Last activity	Latest application event

Field	Description
Actions	View, suspend, restore

Application detail

For each application, show:

- Application key.
- Application version.
- Activation status.
- Entitlement source.
- Trial start and end dates.
- Activation timestamp.
- Suspension reason.
- Application onboarding flow.
- Application roles.
- Application members.
- Branches.
- Usage metrics.
- Application audit events.
- Recent errors.

Superadmin application actions

Read

- View application status.
- View application configuration.
- View application onboarding.
- View application members.
- View application branches.
- View application usage.
- View application activity.
- View application errors.

Edit or administrative actions

- Activate application manually.
- Suspend application.
- Restore application.
- Recalculate application entitlement.
- Restart failed provisioning.
- Mark onboarding step as resolved, with a reason.
- Add an internal support note.

Do not allow in the MVP

- Directly edit inventory products.
- Directly edit stock balances.
- Directly edit sales.
- Directly edit purchase records.
- Silently change application roles.
- Silently change application membership.
- Delete application business data.

The PRD requires stock changes to use stock movements and prohibits silent editing of posted business records. Superadmin tools should follow the same rule.^[2]

8. Branches View

Route:

```
/admin/organizations/:workspaceId/branches
```

The branch view should support both organization-level and application-level branches.

Branch table

Display:

Field	Description
Branch name	Main Store, Warehouse, Abak Road
Branch ID	Internal identifier
Application	Inventory, Tasks, etc.
Status	Active, suspended, archived
Primary branch	Yes or no

Field	Description
Members	Active branch members
Products	Product count where applicable
Stock	Stock summary where applicable
Transactions	Period count
Manager	Assigned branch manager
Created	Creation date
Last activity	Most recent activity
Actions	View, suspend, restore, archive

Branch detail page

Display:

- Branch profile.
- Organization.
- Application.
- Address.
- Phone and email.
- Primary status.
- Branch status.
- Created and updated timestamps.
- Branch members.
- Assigned roles.
- Branch permissions.
- Product and stock summary.
- Sales and transaction summary.
- Synchronization status.
- Branch onboarding.
- Branch audit log.

Branch actions

Read

- View branch profile.
- View branch members.
- View application membership.
- View assigned permissions.
- View usage counts.
- View stock and transaction summaries.
- View branch audit events.
- View failed operations.

Administrative changes

- Suspend branch access.
- Restore branch access.
- Archive branch.
- Restore archived branch.
- Change branch metadata.
- Reassign branch manager.
- Recalculate branch usage.
- Add support note.

Do not allow

- Direct stock balance editing.
- Direct sale editing.
- Direct purchase editing.
- Silent deletion of a branch.
- Deleting a branch that contains historical records.

Archiving should preserve historical records. The existing workspace plan explicitly treats archiving as reversible and data-preserving. ^[1]

9. Members and Teams View

Route:

```
/admin/organizations/:workspaceId/members
```

This page should distinguish:

Workspace membership
Application membership
Branch membership
Role and permissions

Organization member table

Display:

- User name.
- Email.
- User ID.
- Workspace role.
- Application access.
- Branch access.
- Membership status.
- Joined date.
- Last activity.
- Invitation status.
- Account status.
- Actions.

Member drill-down

For each member, display:

- Personal profile summary.
- Workspace membership.
- Application memberships.
- Branch assignments.
- Workspace role.
- Application role.
- Branch role.
- Effective permissions.
- Membership history.
- Invitation history.
- Activity within the organization.
- Last access.
- Suspension history.

Do not expose:

- Password.
- Password hash.
- Raw session tokens.
- TOTP secrets.
- Provider secrets.
- Full private security history.
- Unrelated workspace memberships.
- Unnecessary personal data.

A workspace administrator should control access within that workspace, not the user's personal account. The personal profile plan makes this separation explicit.^[3]

Superadmin member actions

Read

- View member's organization access.
- View application access.
- View branch access.
- View roles and effective permissions.
- View membership audit events.
- View invitation status.
- View last activity.

Edit

- Change workspace role.
- Grant or revoke application access.
- Change application role.
- Change branch assignment.
- Change branch role.
- Suspend organization membership.
- Restore organization membership.
- Revoke organization sessions.
- Revoke pending invitation.

High-risk

- Remove a member from the organization.
- Change the only owner.
- Transfer ownership.
- Grant owner-level permissions.
- Restore a removed member.
- Revoke all sessions.

Removal should mark membership as removed, revoke access, preserve business records, invalidate relevant sessions, notify the user, and create an audit event.^[1]

Never allow

- Set a user's password.
- View a user's password.
- Change a user's personal email.
- Change a user's personal name.
- Disable a user's 2FA directly.
- View raw authentication secrets.
- Delete the user's global account from an organization page.
- Modify memberships in other organizations.

10. Team Counts

The organization overview should show team counts at multiple levels.

Organization level

- Total workspace members.
- Active members.
- Suspended members.
- Removed members.
- Pending invitations.
- Members without application access.
- Members with access to multiple applications.

Application level

- Application members.
- Active application members.
- Suspended application members.
- Members by role.
- Members without branch assignment.
- Members with access to all branches.

Branch level

- Total branch members.
- Active branch members.
- Suspended branch members.
- Members by role.
- Members assigned exclusively to the branch.
- Members assigned to multiple branches.
- Pending branch invitations.

Use precomputed counts or indexed queries. Do not scan every membership record whenever the page loads.

11. Onboarding View

Route:

```
/admin/organizations/:workspaceId/onboarding
```

Display:

- Organization onboarding version.
- Current step.
- Completed steps.
- Skipped steps.
- Failed steps.
- Start date.
- Last update.
- Completion date.
- Application onboarding state.
- Branch setup state.

- Product import status.
- Opening stock status.
- Team invitation status.
- First-sale status.

Superadmin actions

Allowed:

- View onboarding progress.
- View failed step details.
- Retry failed provisioning.
- Mark a support-resolved step as complete.
- Reopen onboarding.
- Add a support note.
- Send a reminder notification.

Every manual onboarding change must include:

- Reason.
- Admin identity.
- Timestamp.
- Before state.
- After state.
- Request ID.

Do not allow the dashboard to silently mark an organization as fully onboarded if required records were not actually created.

12. Billing and Entitlements View

Route:

```
/admin/organizations/:workspaceId/billing
```

Display:

- Billing account ID.
- Billing owner.
- Billing email.
- Selected plan.
- Active plan.

- Billing interval.
- Amount.
- Currency.
- Subscription status.
- Payment status.
- Checkout status.
- Current period.
- Trial period.
- Grace period.
- Paystack transaction references.
- Payment history.
- Invoice history.
- Entitlements.
- Current usage.
- Limit violations.
- Billing consistency status.

Billing consistency warnings

Flag:

- Successful payment with inactive subscription.
- Standard subscription with Free Trial entitlements.
- Active subscription with missing entitlements.
- Duplicate active subscriptions.
- Duplicate payment processing.
- Subscription active after cancellation.
- Payment amount mismatch.
- Currency mismatch.
- Payment reference mismatch.
- Missing Paystack event record.
- Entitlement status different from subscription status.

Billing actions

Read

- View billing state.
- View payment history.
- View invoices.
- View entitlements.
- View usage.
- View billing events.
- View mismatch reports.

Administrative actions

- Recalculate entitlements.
- Retry failed webhook processing.
- Extend trial with a reason.
- Suspend subscription.
- Restore subscription.
- Apply a manual support credit if the billing model supports it.
- Mark a payment as under review.
- Add billing support note.

High-risk actions

- Change active plan.
- Cancel subscription.
- Refund or reverse a payment.
- Modify billing amount.
- Override an entitlement.
- Change billing owner.
- Delete a billing record.

Never delete payment or invoice history. Correct errors through adjustment records or reversal events.

13. Audit Log Design

Route:

```
/admin/organizations/:workspaceId/audit
```

Audit logs should be append-only and searchable.

The workspace plan recommends recording the actor, target entity, timestamp, severity, request ID, and workspace context while excluding sensitive secrets. ^[1]

Audit fields

```
id
workspaceId
actorUserId
actorAdminId
eventType
entityType
entityId
severity
beforeMetadata
afterMetadata
reason
requestId
ipAddress
userAgent
createdAt
```

For privacy and storage cost, avoid storing full large objects in every event. Store only changed fields and safe metadata.

Filters

- Date range.
- Actor.
- Event type.
- Entity type.
- Entity ID.
- Severity.
- Application.
- Branch.
- User.
- Admin action.
- Failed action.
- Security event.

Organization events

Examples:

```
workspace.created
workspace.updated
workspace.archived
```

```
workspace.restored  
workspace.suspended  
workspace.deletion_requested  
workspace.deletion_cancelled  
workspace.deleted  
workspace.ownership_transferred  
workspace.billing_changed  
workspace.entitlements_recalculated
```

Application events

```
application.activated  
application.deactivated  
application.suspended  
application.restored  
application.onboarding_started  
application.onboarding_completed  
application.provisioning_failed  
application.provisioning_retried
```

Branch events

```
branch.created  
branch.updated  
branch.archived  
branch.restored  
branch.suspended  
branch.access_restored  
branch.manager_changed
```

Membership events

```
member.invited  
invitation.accepted  
invitation.revoked  
member.role_changed  
member.application_access_granted  
member.application_access_revoked  
member.branch_access_granted  
member.branch_access_revoked  
member.suspended  
member.restored  
member.removed  
member.sessions_revoked
```

Admin events

```
admin.organization_viewed
admin.application_viewed
admin.branch_viewed
admin.member_viewed
admin.billing_viewed
admin.audit_log_viewed
admin.organization_suspended
admin.organization_restored
admin.organization_archived
admin.application_suspended
admin.branch_suspended
admin.member_suspended
admin.entitlements_recalculated
admin.trial_extended
admin.support_note_created
admin.export_requested
admin.action_failed
```

Viewing sensitive records should itself be audited, especially billing, member security summaries, exports, and administrative activity.

14. Read, Edit, Suspend, Archive, Delete

Use an explicit operation matrix.

Resource	Read	Edit	Suspend / restore	Archive / restore	Delete
Organization profile	Yes	Limited metadata	Yes	Yes	Restricted
Organization billing	Yes	Restricted	Yes	No	No
Application status	Yes	Configuration only	Yes	Deactivate	No
Branch profile	Yes	Limited metadata	Yes	Yes	No destructive delete
Members	Yes	Roles and access	Yes	Membership removal	No account deletion
Invitations	Yes	Resend/revoke	No	No	No; expire or revoke
Usage counters	Yes	Recalculate only	No	No	No
Audit logs	Yes	No	No	No	No
Payments	Yes	Review or adjustment only	No	No	No

Resource	Read	Edit	Suspend / restore	Archive / restore	Delete
Invoices	Yes	Correction record only	No	No	No
Support notes	Yes	Add or edit own note	No	No	Restricted deletion
Stock records	Summary only	No direct editing	No	No	No
Sales records	Summary only	No direct editing	No	No	No
User password	No	No	No	No	No
User 2FA secret	No	No	No	No	No
User global account	Summary only	No direct modification	Account suspension through separate workflow	No	No

The principle should be:

Superadmin can inspect broadly, operate the platform safely, and correct platform state —but must not silently alter customer business records.

15. Confirmation and Security Model

A confirmation message alone is not enough for high-risk actions. Use three levels.

Level 1: Normal confirmation

For low-risk administrative changes:

- Edit organization display name.
- Update branch address.
- Add support note.
- Resend invitation.
- Retry failed onboarding.
- Recalculate usage.

Confirmation modal:

Confirm this action? The system will update the organization record and create an audit event.

Require:

- Explicit confirm button.
- Action summary.

- Target organization.
- Reason field where useful.

Level 2: Re-authentication

For sensitive but routine actions:

- Suspend an organization.
- Restore an organization.
- Suspend a branch.
- Restore a branch.
- Change member role.
- Grant or revoke application access.
- Remove a member.
- Revoke sessions.
- Extend a trial.
- Change billing plan.
- Export organization data.

Require:

- Recent admin authentication.
- Current password, or approved re-authentication method.
- Optional TOTP if enabled.
- Mandatory reason.
- Confirmation phrase for destructive or disruptive actions.

Example:

You are about to suspend Code X Stores. Members may lose access to its applications and branches. Enter the reason and confirm with your admin password.

Level 3: Strong confirmation or dual control

For irreversible or platform-wide actions:

- Delete an organization.
- Delete or anonymize personal data.
- Refund or reverse a payment.
- Transfer organization ownership.
- Grant superadmin privileges.
- Modify plan definitions.
- Change another superadmin's permissions.

- Override billing or entitlement state manually.
- Export sensitive bulk data.

Require:

- Recent password authentication.
- TOTP or security key.
- Confirmation phrase.
- Mandatory reason.
- High-severity audit event.
- Optional second-admin approval.

For an MVP, the safest low-cost approach is to implement the first three authentication requirements and defer full dual approval until the number of administrators increases.

16. PIN Recommendation

A permanent admin PIN should **not** be used as the only security control.

A static PIN can be:

- Shared accidentally.
- Reused across devices.
- Captured by malware.
- Exposed through shoulder surfing.
- Stored insecurely by administrators.
- Used after the admin session has been hijacked.

Recommended design:

```
Admin password
+ recent re-authentication
+ TOTP for high-risk actions
+ optional short confirmation PIN
```

If you still want a PIN, implement it as an additional action-confirmation secret:

- Hash the PIN with a strong password-hashing algorithm.
- Never store or log the raw PIN.
- Never display the PIN after setup.
- Rate-limit attempts.
- Lock the PIN temporarily after repeated failures.
- Require the current admin password to set or change it.

- Require TOTP for changing or disabling it.
- Do not use the same PIN for multiple superadmins.
- Do not use the PIN as a replacement for login or 2FA.
- Audit every failed and successful PIN verification.
- Allow recovery only through a secure re-authentication and administrator recovery process.

For the MVP, use **password re-authentication plus TOTP** first. Add a confirmation PIN only if the workflow proves that repeated password entry is creating friction.

17. Secure Action Flow

Every state-changing admin action should follow this sequence:

1. Authenticate superadmin
2. Verify admin permission
3. Resolve target organization/application/branch
4. Check target status and action eligibility
5. Display exact confirmation summary
6. Request reason
7. Require re-authentication if sensitive
8. Require TOTP or PIN if high-risk
9. Execute server-side mutation
10. Write audit event
11. Send notification if applicable
12. Return updated state

The frontend must never be trusted to decide:

- Whether the admin is a superadmin.
- Which organization is being changed.
- Whether the action is allowed.
- Whether the confirmation occurred.
- Whether the PIN or password is valid.
- Whether the resource belongs to the selected organization.

The backend must receive and verify the target ID, current admin session, action permission, confirmation token, and re-authentication result.

18. Low-Cost Technical Architecture

Use the existing Fastify and Convex architecture.

Backend modules

```
src/modules/admin/  
  admin.routes.ts  
  admin.controller.ts  
  admin.service.ts  
  admin.permissions.ts  
  admin.schemas.ts  
  admin.audit.ts  
  admin.actions.ts  
  
src/modules/admin-organizations/  
src/modules/admin-applications/  
src/modules/admin-branches/  
src/modules/admin-members/  
src/modules/admin-billing/  
src/modules/admin-onboarding/  
src/modules/admin-support/
```

Required backend protections

- requireSuperadmin.
- requireAdminPermission.
- requireRecentAuthentication.
- requireTOTP.
- Optional requireAdminActionPIN.
- Rate limiting.
- Request ID generation.
- Server-side target resolution.
- Audit logging.
- Pagination.
- Search input validation.
- Export restrictions.
- Idempotency for retryable mutations.

Useful admin permissions

```
admin.dashboard.view  
admin.organizations.view  
admin.organizations.suspend  
admin.organizations.restore  
admin.organizations.archive  
admin.organizations.delete  
admin.applications.view  
admin.applications.manage  
admin.branches.view
```

```
admin.branches.manage
admin.members.view
admin.members.manage_access
admin.billing.view
admin.billing.manage
admin.entitlements.recalculate
admin.onboarding.manage
admin.audit.view
admin.support_notes.manage
admin.exports.request
admin.platform_settings.manage
admin.superadmins.manage
```

Do not give every superadmin all permissions automatically. Even if the first version has one superadmin role, model permissions separately so the system can later support support agents, billing administrators, and platform administrators.

19. API Plan

Organization endpoints

```
GET    /v1/admin/organizations
GET    /v1/admin/organizations/:workspaceId/overview
PATCH /v1/admin/organizations/:workspaceId
POST   /v1/admin/organizations/:workspaceId/suspend
POST   /v1/admin/organizations/:workspaceId/restore
POST   /v1/admin/organizations/:workspaceId/archive
POST   /v1/admin/organizations/:workspaceId/restore-archive
POST   /v1/admin/organizations/:workspaceId/recalculate-entitlements
POST   /v1/admin/organizations/:workspaceId/export
```

Application endpoints

```
GET    /v1/admin/organizations/:workspaceId/applications
GET    /v1/admin/organizations/:workspaceId/applications/:productKey
POST   /v1/admin/organizations/:workspaceId/applications/:productKey/suspend
POST   /v1/admin/organizations/:workspaceId/applications/:productKey/restore
POST   /v1/admin/organizations/:workspaceId/applications/:productKey/retry-provision:
```

Branch endpoints

```
GET    /v1/admin/organizations/:workspaceId/branches
GET    /v1/admin/organizations/:workspaceId/branches/:branchId
PATCH /v1/admin/organizations/:workspaceId/branches/:branchId
POST   /v1/admin/organizations/:workspaceId/branches/:branchId/suspend
POST   /v1/admin/organizations/:workspaceId/branches/:branchId/restore
POST   /v1/admin/organizations/:workspaceId/branches/:branchId/archive
```

Member endpoints

```
GET    /v1/admin/organizations/:workspaceId/members
GET    /v1/admin/organizations/:workspaceId/members/:membershipId
PATCH /v1/admin/organizations/:workspaceId/members/:membershipId/role
PATCH /v1/admin/organizations/:workspaceId/members/:membershipId/access
POST   /v1/admin/organizations/:workspaceId/members/:membershipId/suspend
POST   /v1/admin/organizations/:workspaceId/members/:membershipId/restore
POST   /v1/admin/organizations/:workspaceId/members/:membershipId/revoke-sessions
DELETE /v1/admin/organizations/:workspaceId/members/:membershipId
```

Audit and support endpoints

```
GET    /v1/admin/organizations/:workspaceId/audit
GET    /v1/admin/audit
GET    /v1/admin/organizations/:workspaceId/support-notes
POST   /v1/admin/organizations/:workspaceId/support-notes
PATCH /v1/admin/support-notes/:noteId
```

Security endpoints

```
POST   /v1/admin/security/reauthenticate
POST   /v1/admin/security/verify-totp
POST   /v1/admin/security/verify-action-pin
POST   /v1/admin/security/action-confirmation
```

The confirmation endpoint should issue a short-lived, single-use confirmation token bound to:

```
adminUserId
action
targetType
targetId
reason
expiresAt
```

The mutation endpoint must reject the request if any of those values differ from what was confirmed.

20. Data Model Additions

Add or verify these records:

```
adminRoles
adminPermissions
adminRolePermissions
adminUserRoles
adminActionConfirmations
adminReauthenticationEvents
```

```
adminActionPins
adminSupportNotes
adminExports
platformCounters
adminAlerts
```

Admin action confirmation

```
adminActionConfirmations:
  adminUserId
  action
  targetType
  targetId
  reason
  confirmationMethod
  status
  expiresAt
  usedAt
  createdAt
```

Store only confirmation metadata. Never store raw passwords, PINs, TOTP codes, or authentication tokens.

Support notes

```
adminSupportNotes:
  createdByAdminId
  targetType
  targetId
  workspaceId
  note
  visibility
  createdAt
  updatedAt
```

Support notes should not be visible to customers unless you later introduce a customer-facing support system.

21. Implementation Phases

Phase 1: Read-only organization intelligence

Build:

- Overview cards.
- Organization list.
- Organization detail.
- Application list.

- Branch list.
- Member counts.
- Onboarding summary.
- Billing summary.
- Organization audit logs.
- Search and pagination.

This phase gives you operational visibility without exposing dangerous mutations.

Phase 2: Safe operational actions

Add:

- Add support note.
- Retry onboarding.
- Recalculate entitlements.
- Resend or revoke invitations.
- Suspend and restore branch access.
- Suspend and restore application access.
- Suspend and restore organization.
- Revoke organization member sessions.

Require confirmation and audit logging.

Phase 3: Membership and billing administration

Add:

- Change member role.
- Change application access.
- Change branch access.
- Remove membership.
- Extend trial.
- Restore billing state.
- Retry webhook processing.
- Apply controlled billing corrections.

Require recent re-authentication and a reason.

Phase 4: High-risk administration

Add only after the earlier controls are proven:

- Ownership transfer.
- Organization deletion workflow.
- Bulk exports.
- Entitlement overrides.
- Plan management.
- Superadmin management.
- Optional two-person approval.

22. MVP Acceptance Criteria

The first usable version is complete when:

- Superadmin can search every organization.
- Superadmin can open an organization detail page.
- Organization detail shows applications, branches, members, billing, onboarding, usage, and audit history.
- Application counts are visible.
- Branch counts are visible.
- Team counts are visible at organization, application, and branch levels.
- Superadmin can identify each member's application and branch access.
- Audit events are append-only and searchable.
- Sensitive personal secrets are never displayed.
- Read-only pages use pagination and indexed queries.
- Organization suspension requires confirmation.
- Organization restoration requires confirmation.
- Branch and application suspension require confirmation.
- Member access changes require re-authentication.
- High-risk operations require TOTP or an equivalent second factor.
- Every administrative mutation creates an audit event.
- Every action includes the exact target and reason.
- Failed confirmation attempts are rate-limited and logged.
- Business records such as stock, sales, and purchases cannot be directly edited from the dashboard.
- Archived organizations and branches preserve historical data.

- Superadmin actions cannot cross organization boundaries accidentally.

Recommended security decision

For Orviohub's MVP, implement:

Normal action:

Confirmation modal

Sensitive action:

Confirmation + reason + recent password re-authentication

High-risk action:

Confirmation + reason + password re-authentication + TOTP

Destructive/platform-wide action:

Confirmation + reason + password re-authentication + TOTP
+ optional second-admin approval

Use a PIN only as an optional additional confirmation mechanism, not as the primary security control. This gives you strong protection without introducing a costly external approval or security infrastructure system.

✱✱

1. docs/Workspace Management Implementation Plan.pdf
2. docs/Orviohub full PRD.pdf
3. docs/User Personal Profile Management Plan.pdf